

Air University



SSDD (Lab)

Year 2026

Mr. Anjum Rehman

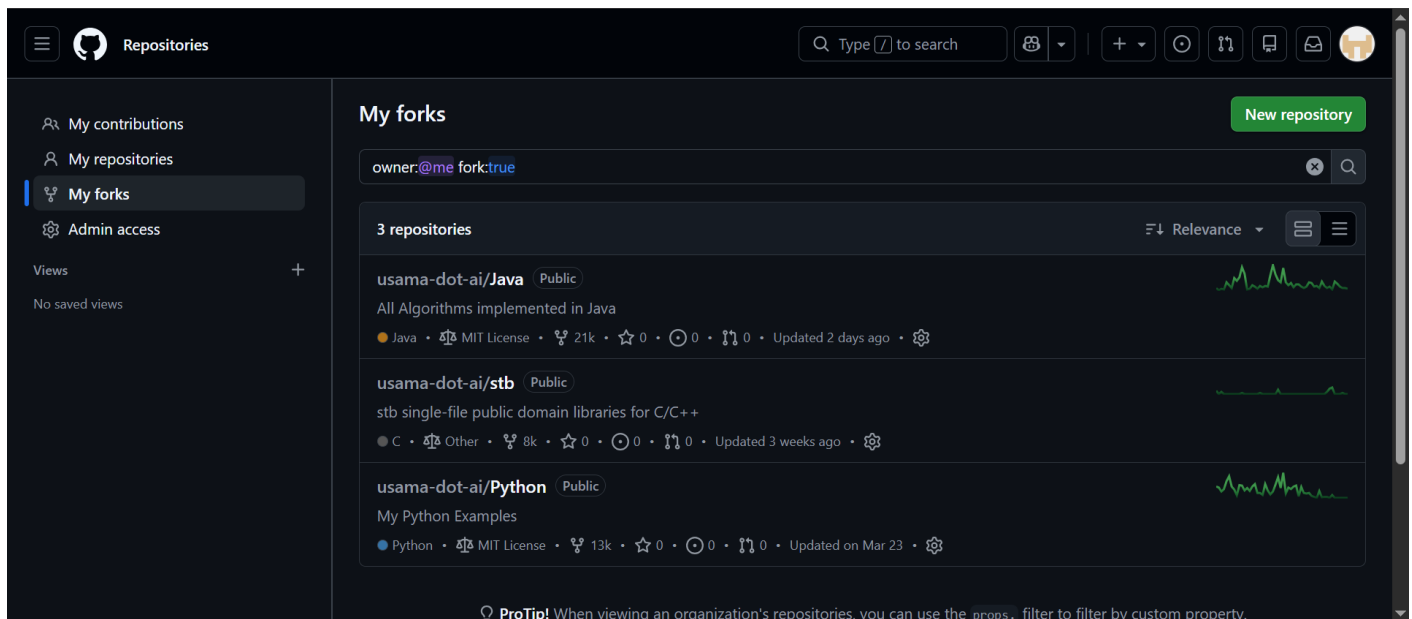
Academic Year: 2024 – 2028
Department of Cyber Security

USAMA ARSHAD | 247141
BS – Cyber Security – Fall – 24 (A)
Date of Submission: May 05, 2026

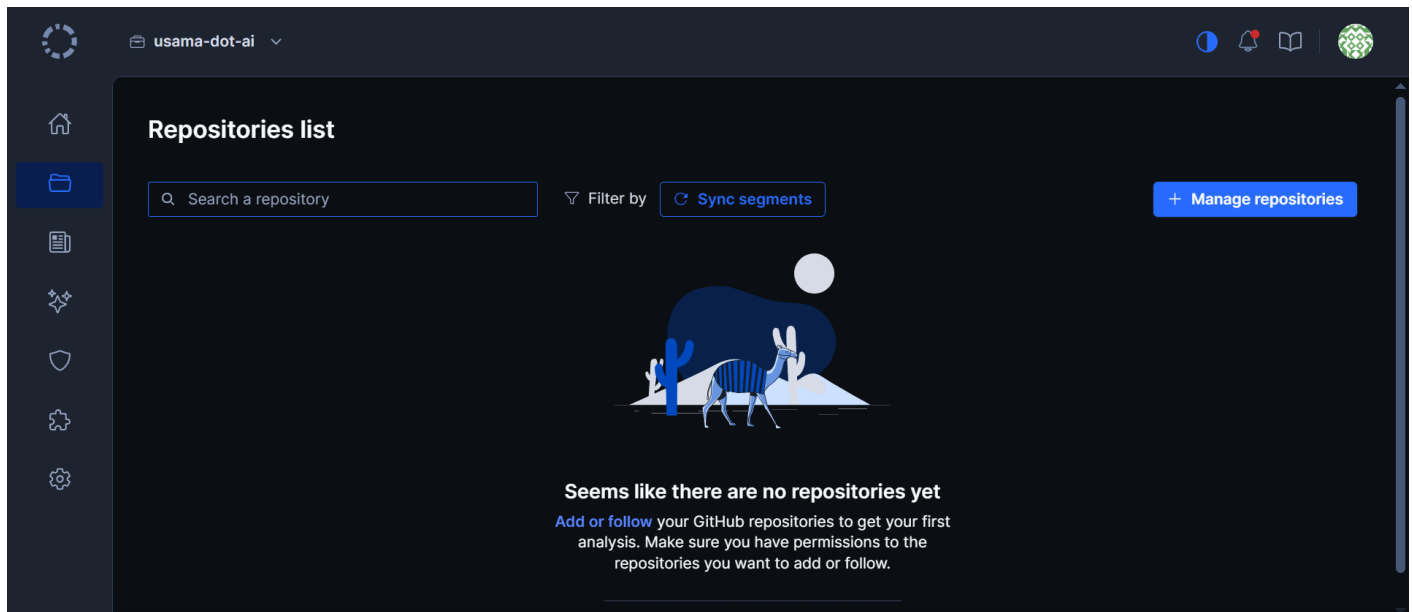
Lab # 08

Task 01:

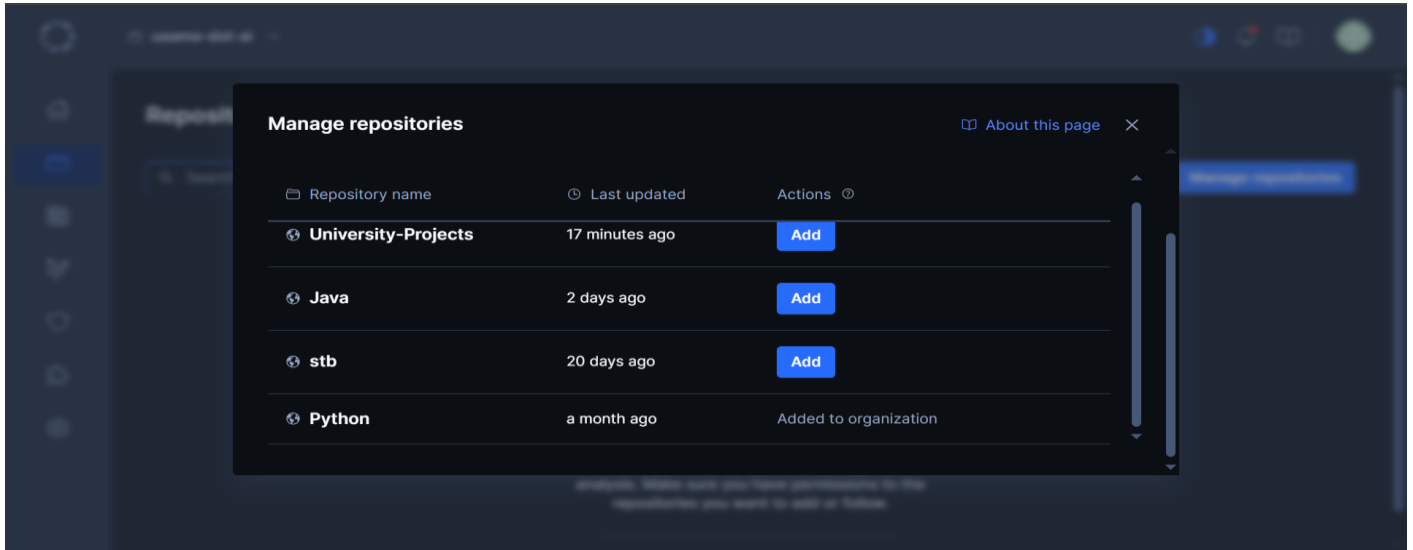
Preparing GitHub repositories:



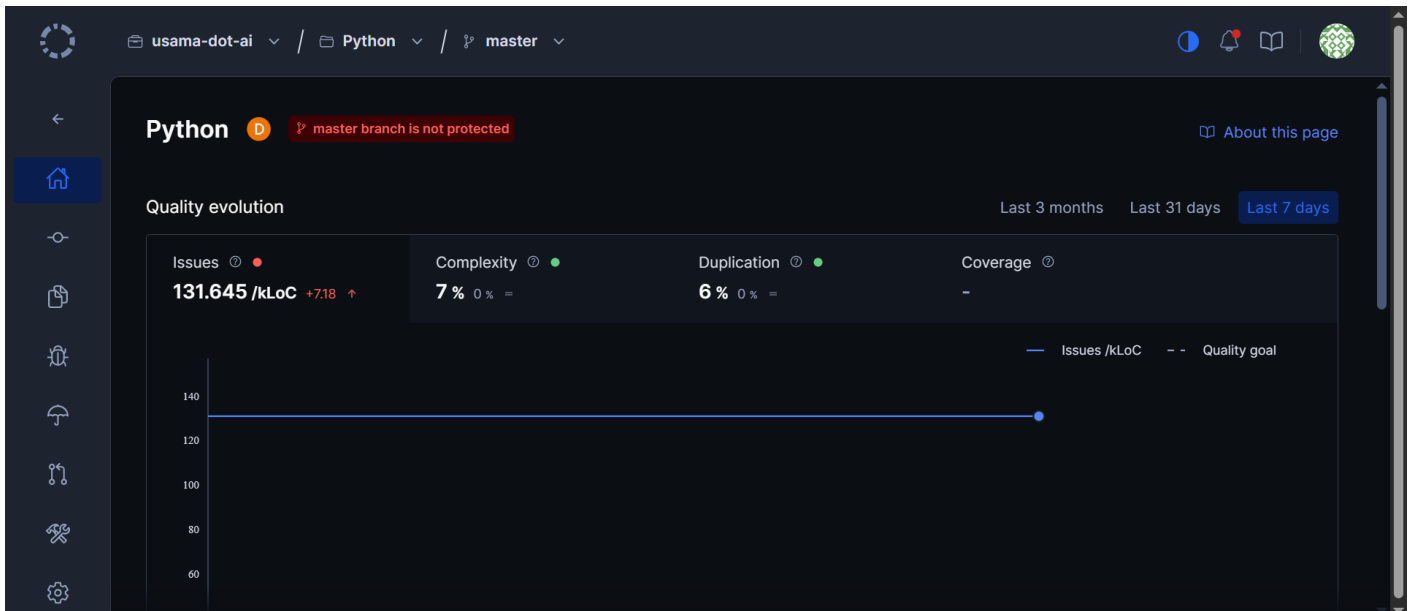
Codacy Setup:



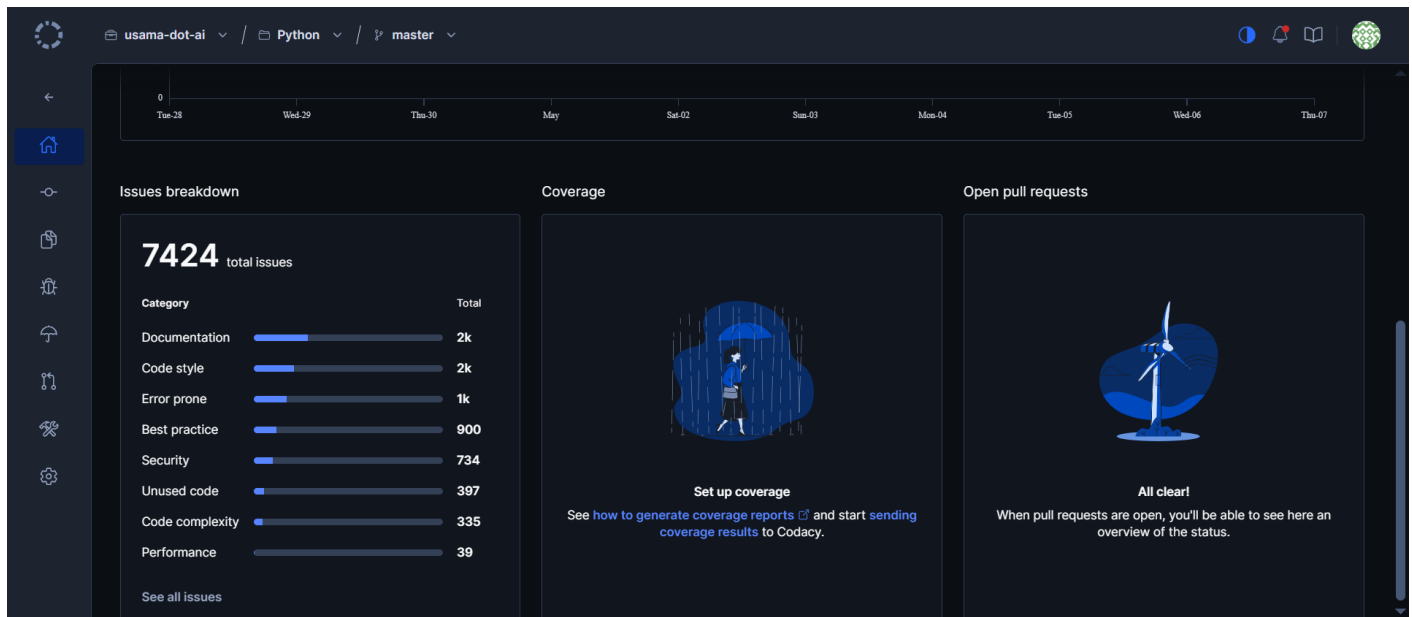
1. Python:



Analysis Results:



Issue Breakdown:



Issue details:

usama-dot-ai / Python / master

Issues

Current 7424 Ignored 0

Filter by Languages Severities 1 Categories 1 Authors Tags Clear all

Create a Jira ticket for these issues

All issues 25

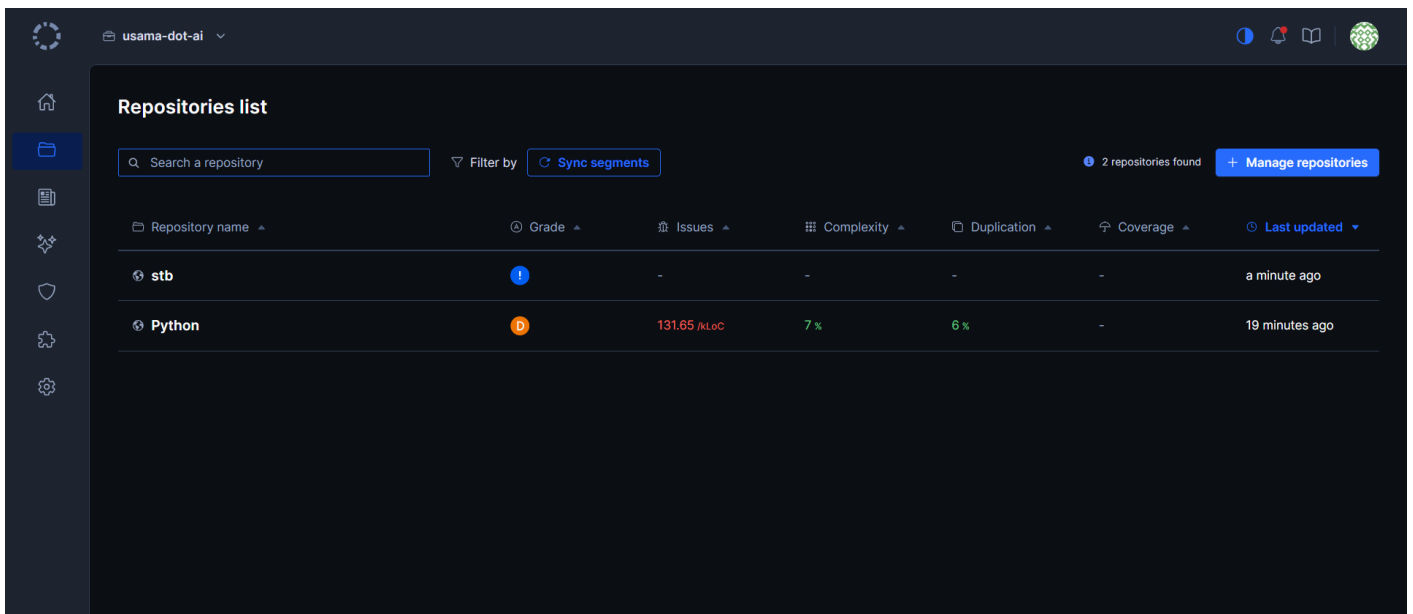
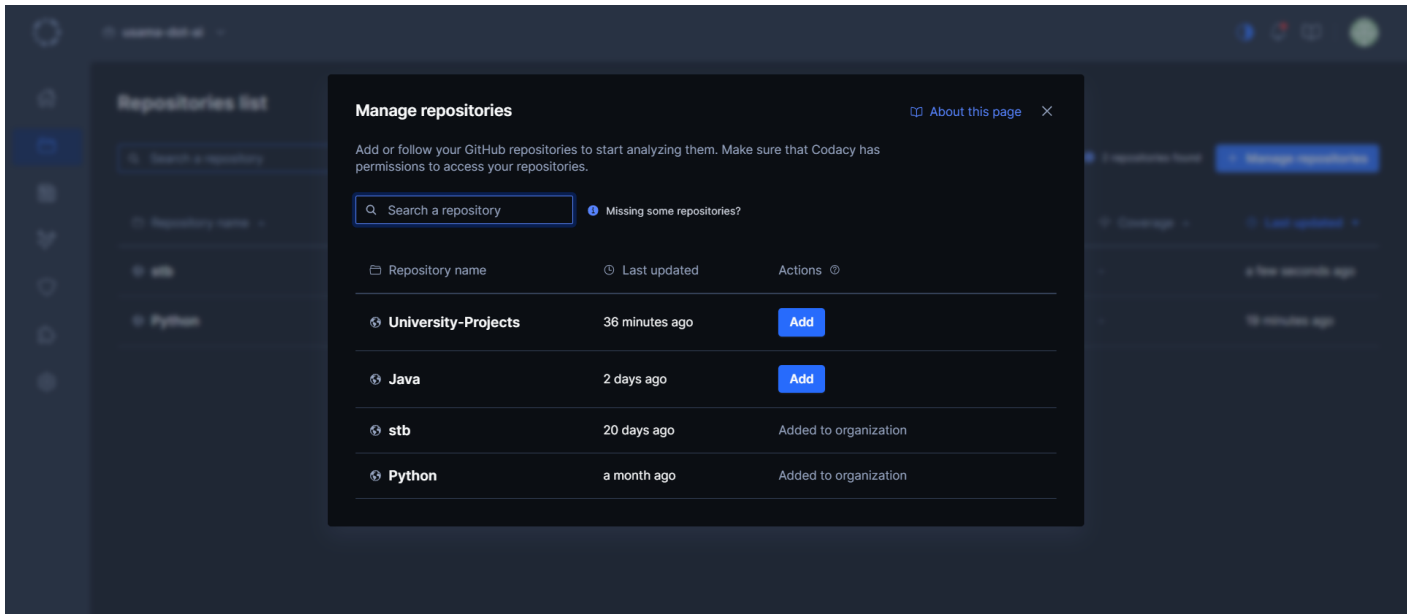
Code patterns

- Avoid subprocess calls with shell=True 7
- Avoid Dangerous Subprocess Use with Taint... 7
- Detect Insecure Dependencies (Critical Sev... 5
- Detect Hardcoded Secrets and Sensitive Inf... 3
- Avoid Unverified SSL Context 2
- Others 1

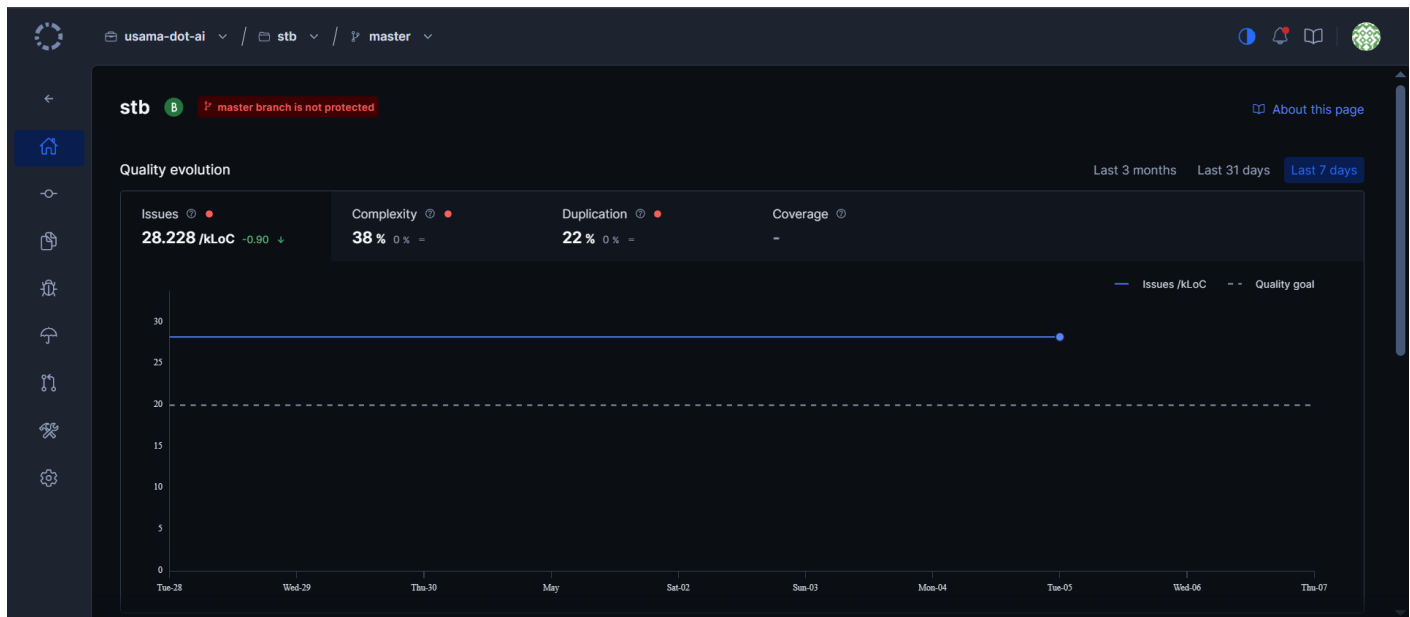
Issues

- CRITICAL** | Security | Insecure Storage
Possible hardcoded secret: Slack Webhook
slack_message.py
1.0 "https://hooks.slack.com/services/T00000000/B00000000/XXXXXXXXXXXXXXXXXXXXXXXXXXXX"
- CRITICAL** | Security | Insecure Storage
Possible hardcoded secret key (secret)
nitkarshchourasia/to_sort/django_projects/ToDo_webapp/todo_site/settings.py
2.3 SECRET_KEY = "django-insecure-5xdo&Zrjq"i)0" g9v@_2e_r6+-102807i\$1pjhc=-19m7yufbz"
- CRITICAL** | Security | Command Injection
Detected subprocess function 'call' with user controlled data.

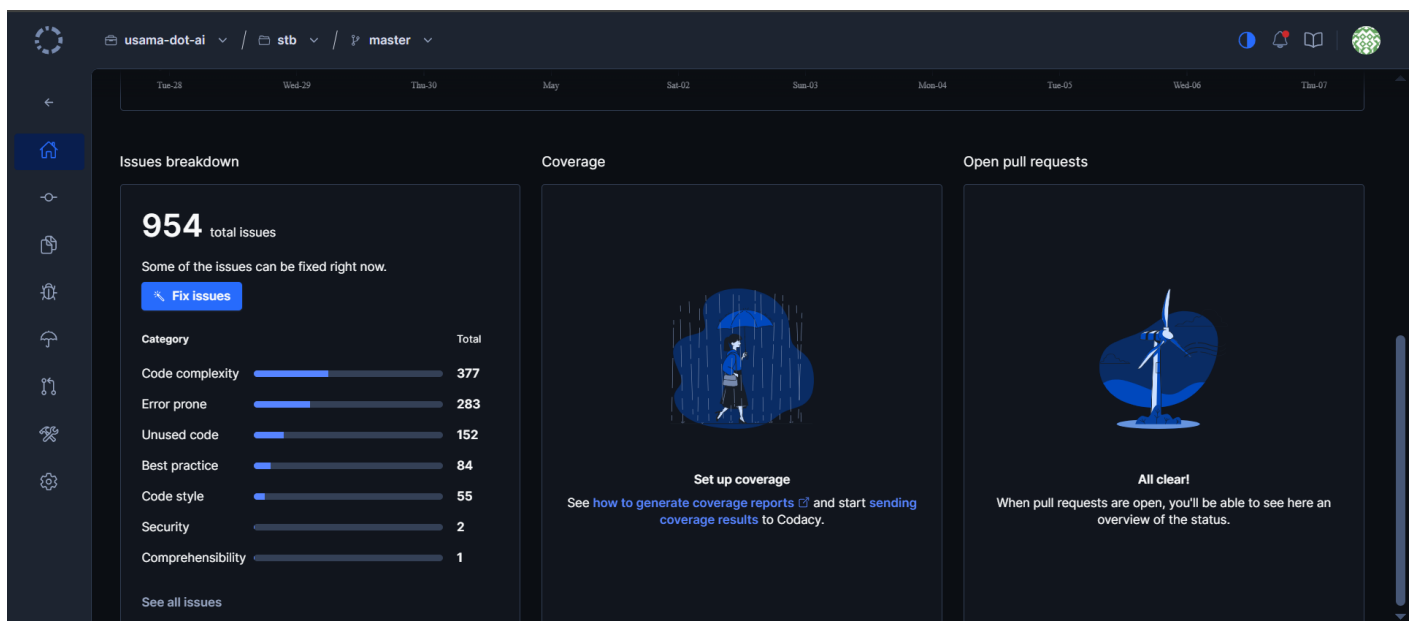
2. C++:



Analysis Results:



Issue Breakdown:



Issue Details:

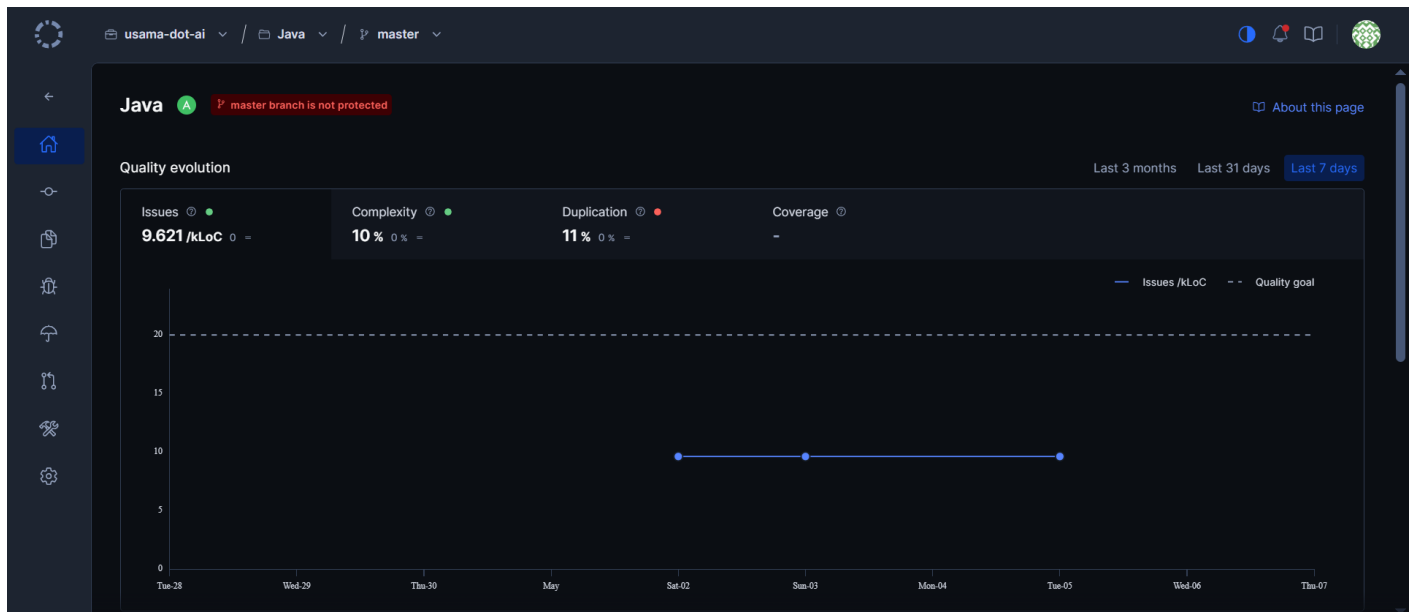
The screenshot shows the GitHub Issues page for the repository `usama-dot-ai/stb` on the `master` branch. The page displays 954 current issues and 0 ignored issues. A notification banner states: "Some of the issues can be fixed right now. You have issues in this branch with a suggested fix that you can apply." Below this, there are filter buttons for Languages, Severities (1), Categories (1), Authors, and Tags. A dropdown menu for Severities is open, showing options for HIGH (2) and MINOR (55). The main content area shows a list of issues. The first issue is titled "An action sourced from a third-party repository on GitHub is not pinned to a full length commit SHA. Pinning an action to a full length commit SHA..." and is categorized as HIGH. The second issue is titled "Enforce Pinning of Third-Party GitHub Action..." and is categorized as MINOR. The third issue is titled "An action sourced from a third-party repository on GitHub is not pinned to a full length commit SHA. Pinning an action to a full length commit SHA..." and is categorized as HIGH. The fourth issue is titled "An action sourced from a third-party repository on GitHub is not pinned to a full length commit SHA. Pinning an action to a full length commit SHA..." and is categorized as HIGH.

3. Java:

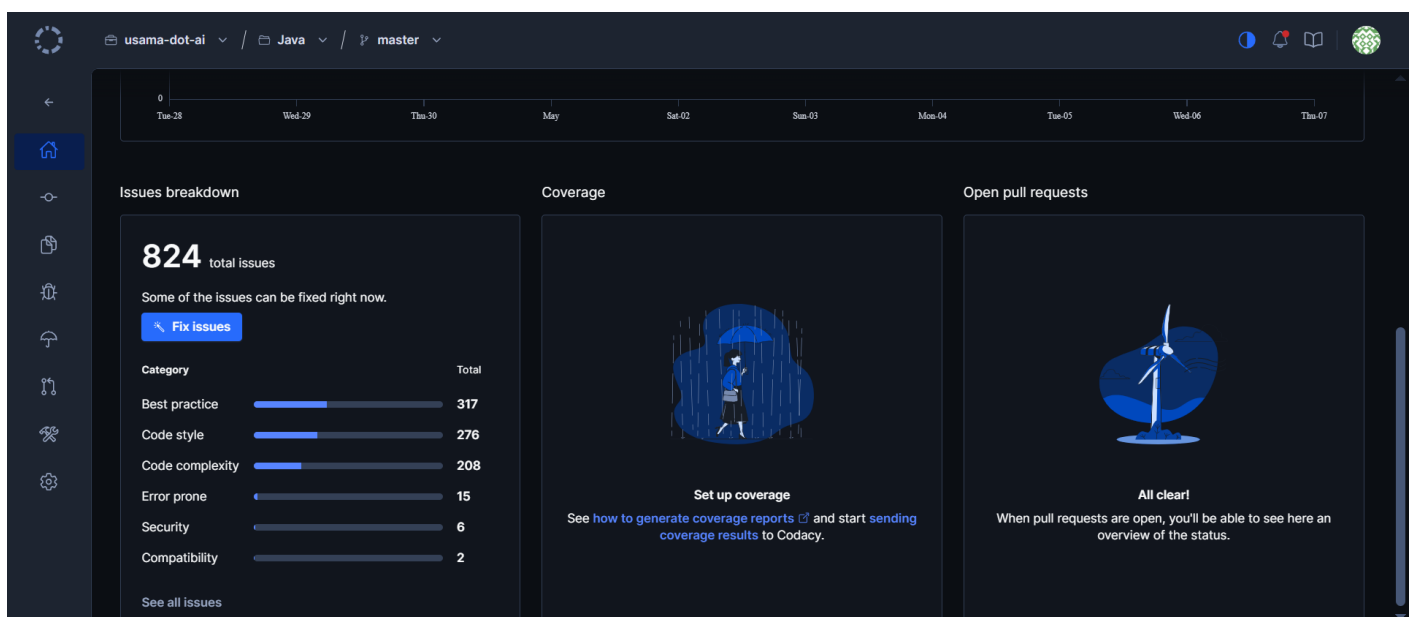
The screenshot shows the GitHub Repositories list page for the repository `usama-dot-ai`. The page displays a table of repositories with columns for Repository name, Grade, Issues, Complexity, Duplication, Coverage, and Last updated. The table contains three rows of data:

Repository name	Grade	Issues	Complexity	Duplication	Coverage	Last updated
stb	B	28.23 kLoC	38 %	22 %	-	7 minutes ago
Python	D	131.65 kLoC	7 %	6 %	-	26 minutes ago
Java	I	-	-	-	-	a few seconds ago

Analysis Results:



Issue Breakdown:



Issue Details:

The screenshot shows the GitHub Issues page for the repository 'usama-dot-ai'. The page is filtered to show 'All issues' with 6 total issues. Two high-severity security issues are highlighted:

- Issue 1:** HIGH | Security | Insecure Modules Libraries. Title: 'An action sourced from a third-party repository on GitHub is not pinned to a full length commit SHA. Pinning an action to a full length commit SHA...'. The issue is located in the file '.github/workflows/update-directorymd.yml' and is caused by the action 'uses peter evans/create pull request@v8'.
- Issue 2:** HIGH | Security | Malicious Code. Title: 'It's possible to embed malicious secret instructions to AI rules files using unicode characters that are invisible to human reviewers. This can lead to...'. The issue is located in the file '.github/workflows/update-directorymd.yml' and is caused by the action 'name Generate Directory Markdown'.

Task 02:

Dynamic Analysis of 1st website:

The screenshot shows the ZAP (Zed Attack Proxy) interface. The main window displays the 'Automated Scan' screen, which allows users to launch an automated scan against an application. The URL to attack is set to 'http://testasp.vulnweb.com/'. The 'Use traditional spider' checkbox is checked, and the 'Use ajax spider' is set to 'If Modern' with 'Firefox' as the browser. The 'Attack' button is visible, and the progress is 'Not started'.

The bottom of the interface shows a table with columns: ID, Source, Req. Timestamp, Method, URL, Code, Reason, RTT, Size Resp. Body, Highest Alert, Note, and Tags. The table is currently empty.

The status bar at the bottom indicates 'Alerts: 0' and 'Current Status: 0'.

Alerts:

The screenshot shows the ZAP 2.17.0 interface with the 'Automated Scan' tab selected. The 'URL to attack' field is set to 'http://testasp.vulnweb.com/'. The 'Use traditional spider' checkbox is checked. The 'Use ajax spider' dropdown is set to 'If Modern' with 'Firefox' selected. The 'Alerts' tab is active, displaying a list of 12 alerts:

- Absence of Anti-CSRF Tokens (2)
- Content Security Policy (CSP) Header Not Set (Systemic)
- Missing Anti-clickjacking Header (Systemic)
- Application Error Disclosure
- Cookie No HttpOnly Flag
- Cookie without SameSite Attribute
- Information Disclosure - Debug Error Messages
- Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (Systemic)
- Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)
- X-Content-Type-Options Header Missing (Systemic)
- Session Management Response Identified (2)
- User Controllable HTML Element Attribute (Potential XSS)

The bottom status bar shows 'Alerts 0 3 7 2' and 'Main Proxy: localhost:8080'.

Dynamic Analysis of 2nd website:

The screenshot shows the ZAP 2.17.0 interface with the 'Automated Scan' tab selected. The 'URL to attack' field is set to 'https://tryhackme.com/'. The 'Use traditional spider' checkbox is checked. The 'Use ajax spider' dropdown is set to 'If Modern' with 'Firefox' selected. The 'Attack' button is highlighted. The 'Progress' bar shows 'Using traditional spider to discover the content'.

The bottom status bar shows 'Alerts 1 3 6 5' and 'Main Proxy: localhost:8080'.

Processed	Method	URI	Flags
✓	GET	https://tryhackme.com/room/securityawarenessintro	
✓	GET	https://tryhackme.com/room/shellsoverview	
✓	GET	https://tryhackme.com/room/uploadvulns	

Alerts:

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Quick Start Request Response Requester

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'. Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack:

History Search Alerts Output Spider AJAX Spider Active Scan

Alerts (16)

- > PII Disclosure (403)
- > Content Security Policy (CSP) Header Not Set (Systemic)
- > Missing Anti-clickjacking Header (Systemic)
- > Sub Resource Integrity Attribute Missing (Systemic)
- > Cookie No HttpOnly Flag (Systemic)
- > Cookie Without Secure Flag (Systemic)
- > Cookie without SameSite Attribute (Systemic)
- > Cross-Domain JavaScript Source File Inclusion (Systemic)
- > Server Leaks Information via "X-Powered-By" HTTP Response
- > Strict-Transport-Security Header Not Set (Systemic)
- > X-Content-Type-Options Header Missing (Systemic)
- > Information Disclosure - Suspicious Comments (412)
- > Modern Web Application (Systemic)
- > Re-examine Cache-control Directives (Systemic)
- > Retrieved from Cache (Systemic)

Full details of any selected alert will be displayed here.

You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.

You can also edit existing alerts by double clicking on them.

Alerts 1 3 7 5 Main Proxy: localhost:8080

Current Status 0 0 1 0 0 0 0 0 0 0 0 0 0 0 0 0

Dynamic Analysis of 3rd website:

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Quick Start Request Response Requester

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'. Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack:

Use traditional spider: ☒

Use ajax spider: with

Progress: Using traditional spider to discover the content

History Search Alerts Output Spider AJAX Spider

New Scan Crawled URLs:0 Export

Processed	ID	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body	Highest Alert	Note	Tags
-----------	----	----------------	--------	-----	------	--------	-----	-------------------	-----------------	---------------	------	------

Alerts 0 4 3 2 Main Proxy: localhost:8080

Current Status 0 0 0 0 0 1 0 0 0 0 0 0 0 0 0 0

Alerts:

The screenshot shows the ZAP 2.17.0 interface. The 'Automated Scan' window is active, displaying a list of 15 alerts. The alerts are categorized by severity: High (3), Medium (5), Low (6), and Information (4). The alerts include:

- Absence of Anti-CSRF Tokens (3)
- Content Security Policy (CSP) Header Not Set (Systemic)
- Cross-Domain Misconfiguration (Systemic)
- Missing Anti-clickjacking Header (Systemic)
- Vulnerable JS Library (2)
- Cookie without SameSite Attribute
- In Page Banner Information Leak (3)
- Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)
- Strict-Transport-Security Header Not Set
- Timestamp Disclosure - Unix (3)
- X-Content-Type-Options Header Missing (Systemic)
- Authentication Request Identified
- Information Disclosure - Suspicious Comments (2)
- Modern Web Application (3)
- Retrieved from Cache

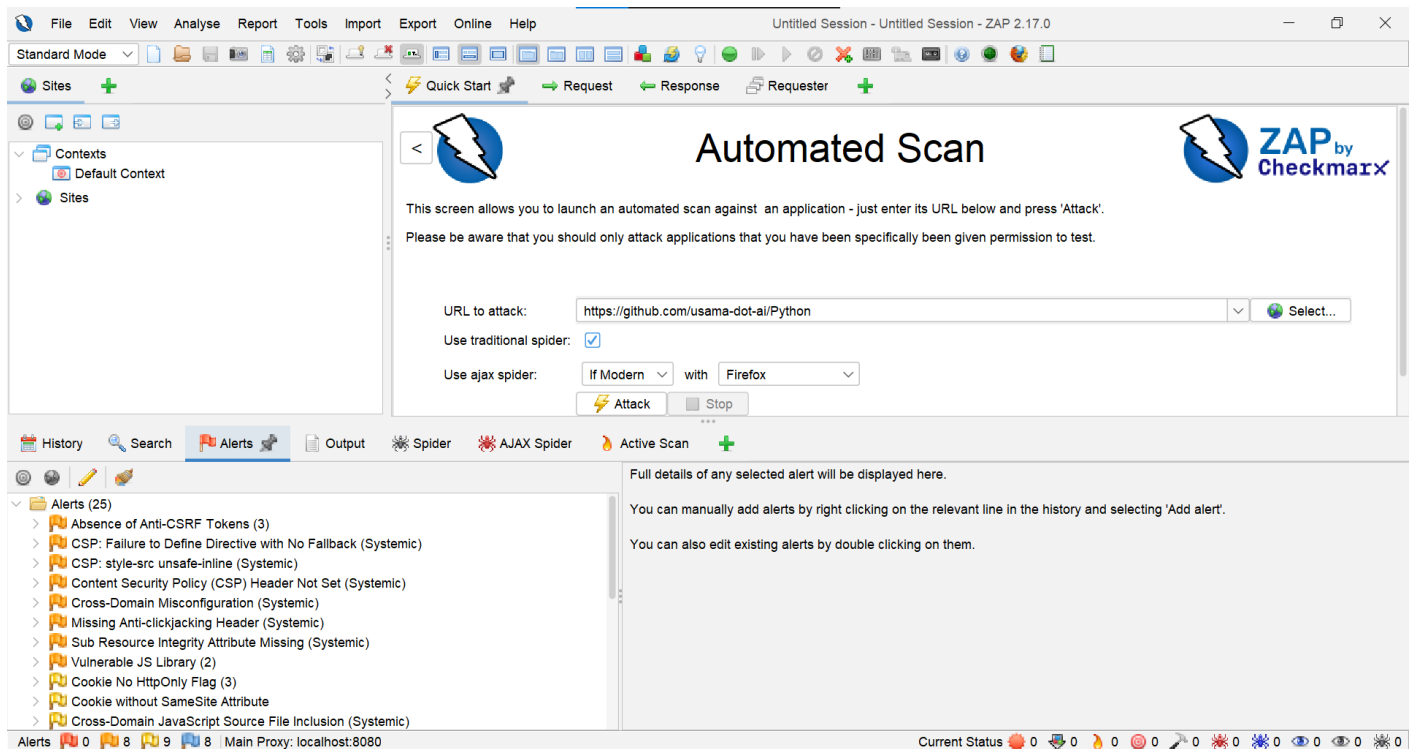
The bottom status bar shows the current status of the scan: Alerts: 0 High, 5 Medium, 6 Low, 4 Information. Main Proxy: localhost:8080. Current Status: 0 High, 0 Medium, 0 Low, 0 Information, 1 Error, 0 Warning, 0 Info, 6 Success, 0 Failed.

Performing an automated scan on Repository:

The screenshot shows the ZAP 2.17.0 interface with the 'Automated Scan' window. The URL to attack is set to <https://github.com/usama-dot-ai/Python>. The scan is using the traditional spider. The progress bar shows 6% completion. The bottom status bar shows the current status of the scan: Alerts: 0 High, 8 Medium, 8 Low, 8 Information. Main Proxy: localhost:8080. Current Status: 0 High, 0 Medium, 0 Low, 0 Information, 0 Error, 0 Warning, 0 Info, 8 Success, 1 Failed.

URLs	Added Nodes	Messages
Processed		
POST		https://github.com/signup?social=false
GET		https://github.com/signup?return_to=https%3A%2F%2Fgithub.com%2F%2A%2F...
POST		https://github.com/session
GET		https://github.com/login?return_to=https%3A%2F%2Fgithub.com%2F%2A%2F...
POST		https://github.com/session

Alerts:



The screenshot shows the ZAP 2.17.0 interface in 'Standard Mode'. The 'Automated Scan' tab is active, displaying a form to launch an automated scan. The 'URL to attack' field is set to 'https://github.com/usama-dot-ai/Python'. The 'Use traditional spider' checkbox is checked. The 'Use ajax spider' dropdown is set to 'If Modern' with 'Firefox' selected. The 'Attack' button is highlighted. The left sidebar shows a tree view with 'Contexts' and 'Sites'. The bottom status bar indicates 'Alerts 0' and 'Main Proxy: localhost:8080'.

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'. Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack: Select...

Use traditional spider: ☒

Use ajax spider: If Modern with Firefox

Attack Stop

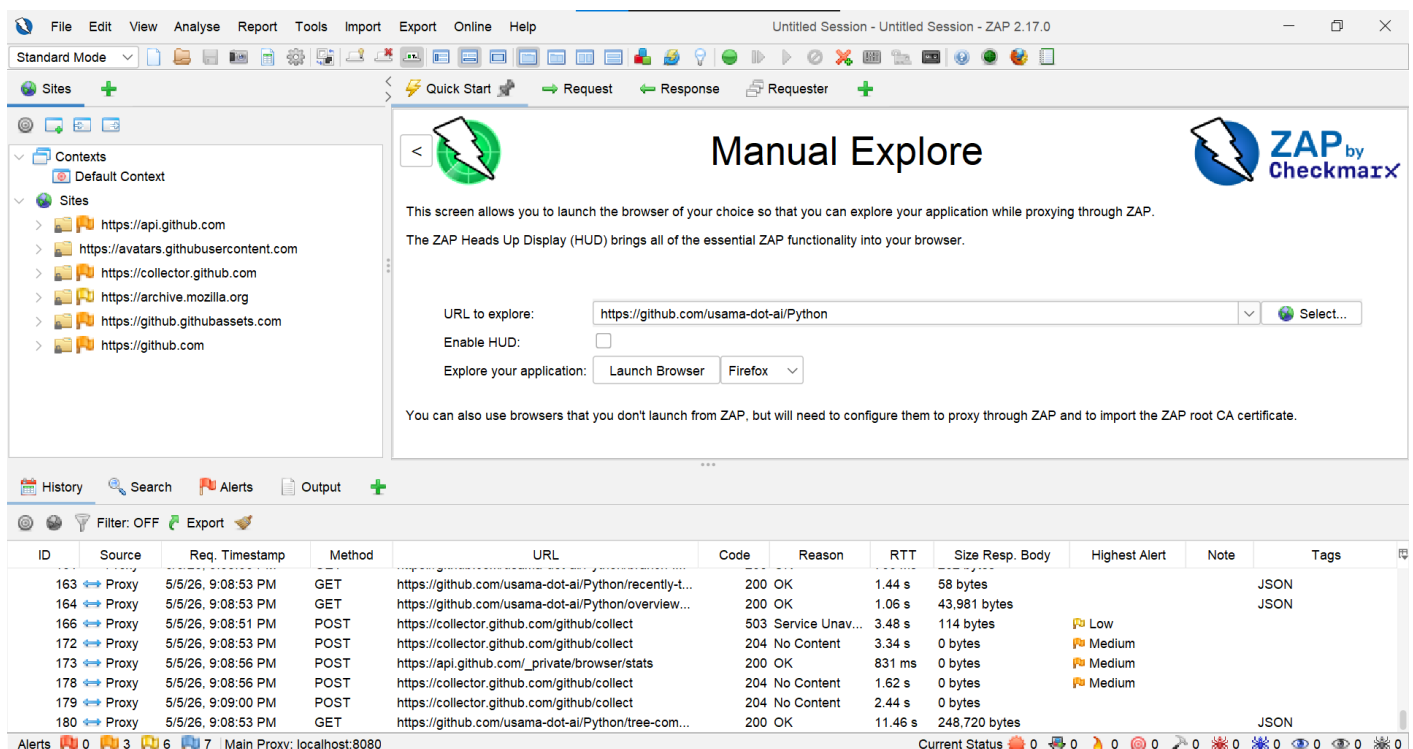
Full details of any selected alert will be displayed here.

You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.

You can also edit existing alerts by double clicking on them.

Alerts 0 8 9 8 Main Proxy: localhost:8080

Performing a manual scan on the repository:



The screenshot shows the ZAP 2.17.0 interface in 'Standard Mode'. The 'Manual Explore' tab is active, displaying a form to launch a manual scan. The 'URL to explore' field is set to 'https://github.com/usama-dot-ai/Python'. The 'Enable HUD' checkbox is unchecked. The 'Explore your application' dropdown is set to 'Launch Browser' with 'Firefox' selected. The 'Launch Browser' button is highlighted. The left sidebar shows a tree view with 'Contexts' and 'Sites'. The bottom status bar indicates 'Alerts 0' and 'Main Proxy: localhost:8080'.

Manual Explore

This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP. The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.

URL to explore: Select...

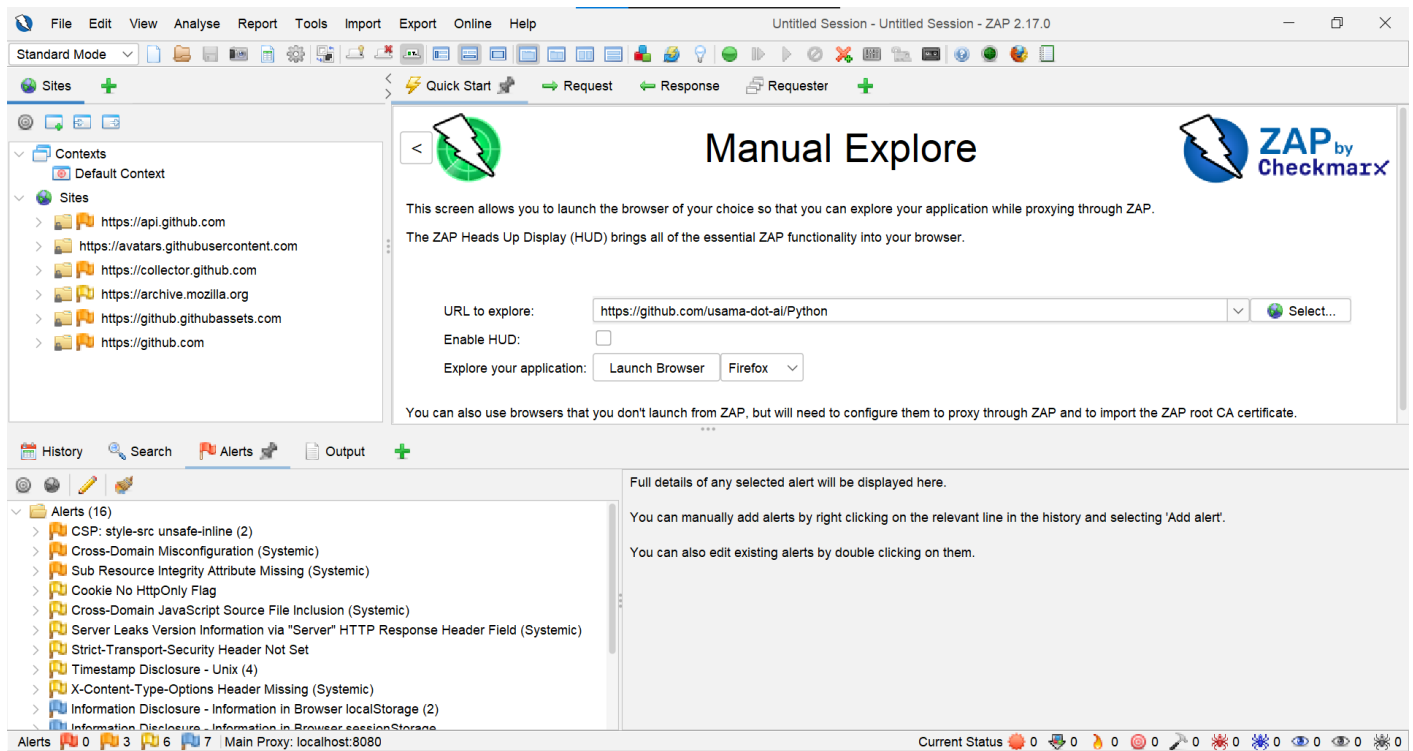
Enable HUD: ☐

Explore your application: Launch Browser Firefox

You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
163	Proxy	5/5/26, 9:08:53 PM	GET	https://github.com/usama-dot-ai/Python/recently-t...	200	OK	1.44 s	58 bytes			JSON
164	Proxy	5/5/26, 9:08:53 PM	GET	https://github.com/usama-dot-ai/Python/overview...	200	OK	1.06 s	43,981 bytes			JSON
166	Proxy	5/5/26, 9:08:51 PM	POST	https://collector.github.com/github/collect	503	Service Unav...	3.48 s	114 bytes	Low		
172	Proxy	5/5/26, 9:08:53 PM	POST	https://collector.github.com/github/collect	204	No Content	3.34 s	0 bytes	Medium		
173	Proxy	5/5/26, 9:08:56 PM	POST	https://api.github.com/_private/browser/stats	200	OK	831 ms	0 bytes	Medium		
178	Proxy	5/5/26, 9:08:56 PM	POST	https://collector.github.com/github/collect	204	No Content	1.62 s	0 bytes	Medium		
179	Proxy	5/5/26, 9:09:00 PM	POST	https://collector.github.com/github/collect	204	No Content	2.44 s	0 bytes			
180	Proxy	5/5/26, 9:08:53 PM	GET	https://github.com/usama-dot-ai/Python/tree-com...	200	OK	11.46 s	248,720 bytes			JSON

Alerts 0 3 6 7 Main Proxy: localhost:8080

Alerts:

The screenshot displays the ZAP 2.17.0 interface in 'Manual Explore' mode. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled 'Untitled Session - Untitled Session - ZAP 2.17.0'. On the left, the 'Sites' pane shows a list of discovered sites, including https://api.github.com, https://avatars.githubusercontent.com, https://collector.github.com, https://archive.mozilla.org, https://github.githubassets.com, and https://github.com. The central pane, titled 'Manual Explore', contains instructions on how to launch a browser to explore an application while proxying through ZAP. It features a 'URL to explore' field with the value 'https://github.com/usama-dot-ai/Python', an 'Enable HUD' checkbox, and a dropdown menu for 'Explore your application' set to 'Launch Browser'. Below this, a status bar shows 'Current Status' with various icons and counts (0, 0, 0, 0, 0, 0, 0, 0, 0, 0). The bottom pane, titled 'Alerts (16)', lists several security alerts, such as 'CSP: style-src unsafe-inline (2)', 'Cross-Domain Misconfiguration (Systemic)', 'Sub Resource Integrity Attribute Missing (Systemic)', 'Cookie No HttpOnly Flag', 'Cross-Domain JavaScript Source File Inclusion (Systemic)', 'Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)', 'Strict-Transport-Security Header Not Set', 'Timestamp Disclosure - Unix (4)', 'X-Content-Type-Options Header Missing (Systemic)', and 'Information Disclosure - Information in Browser localStorage (2)'. The bottom status bar also shows 'Alerts' with counts (0, 3, 6, 7) and 'Main Proxy: localhost:8080'.

- End of Lab Task -